

BankSentinel: A Five-Agent AI-Driven Intrusion Detection System for Real-Time Threat Correlation in Banking Networks

Ankit Kumar Karn

Computer Science and Engineering
Kathmandu University School of Engineering
Dhulikhel, Nepal
ankarn07@gmail.com

Aditya Shrestha

Computer Science and Engineering
Kathmandu University School of Engineering
Dhulikhel, Nepal
adityastha007@gmail.com

Aashwot Acharya

Computational Mathematics
Kathmandu University School of Science
Dhulikhel, Nepal
ashwot1133@gmail.com

Kshitiz Khanal

Computer Science and Engineering
Kathmandu University School of Engineering
Dhulikhel, Nepal
kshitizkhanal123@gmail.com

Royas Shakya

Computer Science and Engineering
Kathmandu University School of Engineering
Dhulikhel, Nepal
shkroyas@gmail.com

Abstract—Existing intrusion detection systems (IDS) deployed in banking environments rely on signature-based rules and isolated anomaly detectors that fail to identify coordinated Advanced Persistent Threat (APT) campaigns, zero-day exploits, encrypted Command-and-Control (C2) beaconing, and insider threats. We present BankSentinel, a five-agent, multi-modal AI-driven IDS engineered specifically for high-security financial networks including SWIFT messaging subnets, ATM switch networks, and core banking infrastructure (Pumori/Pumori+). BankSentinel deploys a hierarchical agent pipeline: (1) a *Packet Agent* performing deep protocol analysis via Zeek/Suricata with JA3/JA3S TLS fingerprinting for encrypted traffic; (2) a *Flow Agent* applying Isolation Forest anomaly detection trained on institution-specific NetFlow/IPFIX baselines; (3) a *Behavior Agent* providing User and Entity Behavior Analytics (UEBA) over Windows Event Logs and privileged account telemetry; (4) a *Correlation Agent* fusing multi-agent alerts into MITRE ATT&CK-aligned threat narratives with active alert-fatigue suppression; and (5) a *Response Agent* executing sub-second automated containment via network ACLs, account suspension, and forensic timestamping. Alert fusion employs a Bayesian Belief Network with SHAP-based explainability. Evaluated on CICIDS-2018 [12], CTU-13 [13], UNSW-NB15 [14], and a synthetic banking dataset (BankSim-2024) reflecting NRB-regulated network segments, BankSentinel achieves a detection rate of 98.3% with a false positive rate of 0.07%, identifies correlated multi-stage APT campaigns within 38 seconds, and reduces SOC analyst mean response time from 14.2 minutes to 3.8 minutes.

Index Terms—Intrusion Detection System, Multi-Agent System, JA3/JA3S TLS Fingerprinting, Isolation Forest, UEBA, MITRE ATT&CK, Zeek, Suricata, Alert Fatigue, Banking Se-

curity, SWIFT, ATM Network, APT Detection, Explainable AI

I. PROBLEM DESCRIPTION

The financial services sector remains the most targeted vertical for sophisticated cyberattacks, accounting for 23% of all reported data breaches globally in 2024 [1]. Nepalese banking networks present a particularly heterogeneous threat surface: they operate legacy COBOL mainframes, SWIFT messaging gateways, real-time gross settlement (RTGS) systems, Pumori/Pumori+ core banking platforms, and modern ATM switch infrastructure — all of which must remain continuously available while sustaining enterprise-grade security postures and compliance with NRB Cybersecurity Guidelines.

Traditional NIDS such as Snort and Suricata operate on handcrafted signature libraries that are inherently reactive and cannot detect zero-day vulnerabilities or coordinated multi-stage attacks. This limitation was starkly demonstrated in the 2016 Bangladesh Bank SWIFT heist, where attackers maintained persistent access for weeks before executing fraudulent transactions, evading all signature-based controls [2].

A. Core Challenges

Modern banking security faces four compounding challenges that no existing system fully addresses:

- 1) **Zero-day attacks** have no known signature and must be detected via behavioral deviation alone.
- 2) **Legitimate high-volume patterns** — month-end batch processing, ATM reconciliation windows, RTGS settlement cycles — superficially resemble DoS or exfiltration, causing endemic false positives.
- 3) **Alert fatigue**: banking SOCs receive tens of thousands of alerts daily; without intelligent suppression, analysts become desensitized and miss genuine threats.
- 4) **Encrypted traffic**: the ubiquity of TLS 1.3 means payload inspection is infeasible; threats must be identified from connection metadata and TLS handshake fingerprints alone.

B. Banking Network Context

BankSentinel is designed for the following network segments common in Nepalese commercial banks:

- **SWIFT Subnet**: SWIFT Alliance Gateway workstations and message broker nodes
- **Core Banking**: Pumori and Pumori+ application servers and their database tiers
- **ATM Switch Network**: Euronet/ACI-based switch servers and ATM concentrators
- **NRB Regulatory Network**: Interfaces to Nepal Rastra Bank reporting and RTGS gateways
- **Corporate LAN**: Staff workstations, Active Directory, email, and internal web services

C. Adversary Model

We model adversaries possessing: persistent network access via initial compromise of a low-privilege endpoint; the ability to perform reconnaissance and lateral movement within VLAN-segmented subnets; use of encrypted or low-entropy C2 channels including TLS tunneling; and the capability to disguise malicious activity within legitimate banking operational patterns, such as initiating data exfiltration during ATM reconciliation windows.

D. Formal Problem Statement

Let $G_t = (V, E_t)$ be the network communication graph at time t . Let $S_t = \{s_1, \dots, s_n\}$ be the multivariate time series of network and behavioral features. Let $\mathcal{A} = \{A_{\text{pkt}}, A_{\text{flow}}, A_{\text{beh}}\}$ be alerts from the three detection agents. We seek a detection function:

$$D : (G_t, S_t, L_t, \mathcal{A}) \rightarrow \{0, 1\} \times [0, 1] \times \mathcal{T} \quad (1)$$

where L_t is the log event stream, $\{0, 1\}$ is the binary alert decision, $[0, 1]$ is the composite risk score, and $\mathcal{T}$ is the MITRE ATT&CK tactic set. The objective is to maximize detection rate DR subject to false positive rate $\text{FPR} \leq \epsilon$ (where $\epsilon = 0.1\%$ per banking SLAs) and detection latency $\tau \leq 60$ seconds.

E. Motivating Scenario

The primary motivating scenario is a coordinated APT campaign: at 03:18:07 UTC, a workstation (10.22.14.45) in the SWIFT messaging subnet initiates outbound TLS connections to 185.220.101.32 (Eastern Europe, Tor exit node, no prior communication history). The JA3 fingerprint matches a known Cobalt Strike C2 profile. Simultaneously, privileged service account `svc_corebanking` executes 400 SELECT queries against the Pumori core banking database within 120 seconds. The Flow Agent detects deviation from the month-end baseline; the Behavior Agent detects anomalous privileged query volume; and the Correlation Agent fuses both signals into a high-confidence APT campaign alert mapped to MITRE techniques T1071.001, T1078, and T1213.

II. RELATED WORKS

A. Signature-Based and Statistical IDS

Rule-based systems such as Snort [3] and Suricata achieve near-zero false positives for known attacks but fail entirely on novel exploit variants. Statistical approaches including CUSUM and EWMA-based detectors model traffic baselines but cannot capture the non-stationary, multi-variate nature of banking traffic [4].

B. Machine Learning Approaches

Supervised classifiers including Random Forests [15] and SVMs require labeled attack data, which is scarce in operational banking due to regulatory constraints. Isolation Forest [5] and one-class SVMs show promise for unsupervised anomaly detection. KitNET [6] introduced ensemble autoencoders for online anomaly detection without pre-labeled data.

C. Behavioral and Insider Threat Detection

UEBA platforms such as Splunk UBA and Microsoft Sentinel apply machine learning to user and entity behavioral baselines. DeepLog [7] applied LSTMs to system log anomaly detection. However, these approaches operate in isolation and do not integrate with network-layer detection pipelines.

D. Graph-Based Network Anomaly Detection

NetWalk [8] and MIDAS [9] demonstrated that structural changes in communication graphs carry strong attack signal. Our approach incorporates graph anomaly scoring within the Correlation Agent's multi-signal fusion layer.

E. Encrypted Traffic Analysis

Anderson et al. [10] demonstrated that JA3 TLS fingerprinting achieves 93.5% accuracy for malware family classification without decryption. Salesforce's JA3S extended this to server-side fingerprinting. No existing banking IDS integrates JA3/JA3S at scale within a multi-agent architecture.

F. Experimental Datasets

Publicly available benchmark datasets used across the IDS research community, and adopted in this work, are described below.

CICIDS-2018 [12]: Sharafaldin et al. introduced the Canadian Institute for Cybersecurity Intrusion Detection Evaluation Dataset 2018, comprising 16.2 million flows across 14 attack categories including DoS, DDoS, botnet, infiltration, and web-based attacks, collected over 10 days on a realistic network testbed. The dataset is publicly available via the AWS Open Data Registry at <https://registry.opendata.aws/cse-cic-ids2018/>.

CTU-13 [13]: Garcia et al. published the CTU University botnet dataset containing 23 real botnet scenarios captured on the CTU university network in Prague, covering botnet families including Neris, Rbot, Virut, and Menti, each with documented C2 communication channels. It is maintained by the Stratosphere IPS Research Group and available at <https://www.stratosphereips.org/datasets-ctu13>.

UNSW-NB15 [14]: Moustafa and Slay presented the UNSW-NB15 dataset comprising 2.5 million records with 49 features across 9 attack categories including Fuzzers, Analysis, Backdoors, DoS, Exploits, Generic, Reconnaissance, Shellcode, and Worms, generated using the IXIA PerfectStorm tool in a hybrid testbed environment. The dataset is available via UNSW Canberra Cyber at <https://research.unsw.edu.au/projects/unsw-nb15-dataset>.

G. Gap Analysis

No existing system simultaneously addresses (1) zero-day detection via bank-specific behavioral baselines, (2) JA3/JA3S encrypted traffic analysis, (3) UEBA-based insider threat detection, (4) alert-fatigue suppression through intelligent correlation, and (5) sub-second automated response — all within a banking-specific deployment context. BankSentinel is the first unified architecture addressing all five requirements concurrently.

III. PROPOSED METHODOLOGY

BankSentinel is organized as a five-agent hierarchical pipeline over four infrastructure layers: Data Ingestion, Stream Processing, Agent Execution, and Response Orchestration.

System Contributions. This paper makes the following contributions:

- 1) A unified five-agent IDS architecture combining packet-level, flow-level, and behavioral detection with Bayesian alert fusion, designed for Nepalese and South Asian banking regulatory and operational constraints.
- 2) A *Packet Agent* integrating Zeek and Suricata with JA3/JA3S TLS fingerprinting to detect threats inside encrypted sessions without decryption.
- 3) A *Flow Agent* using Isolation Forest trained on institution-specific NetFlow/IPFIX traffic, automatically distinguishing legitimate high-volume banking patterns from genuine anomalies.

- 4) A *Behavior Agent* implementing UEBA over Windows Event Logs, privileged account activity, and endpoint telemetry for insider threat and credential-abuse detection.
- 5) A *Correlation Agent* that reduces alert volume by 87% through redundancy suppression while maintaining 100% campaign-level detection rate on synthetic APT scenarios.
- 6) A *Response Agent* achieving sub-500ms network quarantine via NETCONF/YANG ACL updates with full forensic audit trails compliant with PCI-DSS 10.3.

A. Data Ingestion Layer

BankSentinel ingests six telemetry streams via Apache Kafka with strict ordering guarantees:

- **Raw Packets / Zeek/Suricata Logs:** Protocol-level events from inline network taps on all monitored subnets, including extracted TLS metadata (JA3/JA3S fingerprints, SNI, certificate subjects)
- **NetFlow v9/IPFIX:** Bidirectional flow metadata (IP 5-tuple, byte/packet counts, flow duration, DSCP markings)
- **Windows Event Logs:** Security events (4624, 4625, 4648, 4688, 4698, 4769) from all domain-joined endpoints via Winlogbeat
- **SIEM Log Stream:** Authentication, privilege escalation, and database query logs from Elastic SIEM
- **SWIFT Traffic Metadata:** Application-layer message counts and timing from SWIFT Alliance Gateway (payload excluded per compliance)
- **EDR Telemetry:** Process creation, registry, and filesystem events from 847 monitored hosts

All streams are normalized to a unified schema and time-aligned via a 10-second sliding window buffer with 2-second stride.

B. Stream Processing Layer

An Apache Kafka – Apache Flink pipeline performs real-time feature engineering including: inter-arrival time (IAT) statistics per flow quintuple; payload entropy estimation via 256-bin histogram; bidirectional flow aggregation with 60-second tumbling windows; JA3 hash computation from TLS ClientHello fields; and behavioral feature extraction covering session frequency, privilege escalation sequences, and query rate per account. Computed features are partitioned by source subnet and multicast to all agent consumers.

C. Agent 1: Packet Agent

1) *Role and Scope:* The Packet Agent performs per-packet analysis using Zeek and Suricata for protocol anomalies, malformed headers, and unusual payload patterns. It is the primary agent for detecting known CVEs via updated Suricata signatures and for all encrypted traffic analysis.

2) *Zeek Protocol Analysis*: Zeek is deployed as an inline sensor on all subnet boundaries. Its scripting engine extracts: protocol deviation logs (`weird.log`) covering malformed DNS and HTTP anomalies; connection meta-data (`conn.log`) with full 5-tuple statistics; TLS metadata (`ssl.log`) including cipher suites, certificate validity, and SNI; and HTTP/SMTP application logs for cleartext protocol anomalies. Suricata runs in parallel with the Emerging Threats Pro ruleset supplemented by custom banking rules targeting SWIFT API misuse and Pumori database port scanning.

3) *JA3/JA3S TLS Fingerprinting*: For encrypted traffic, BankSentinel computes JA3 fingerprints from TLS ClientHello messages and JA3S fingerprints from ServerHello responses without decryption. The JA3 hash is derived as:

$$JA3 = MD5(\text{Version, Ciphers, Extensions, EllipticCurves, PointFormats}) \quad (2)$$

A curated threat intelligence database of 14,200 known-malicious JA3 fingerprints (sourced from abuse.ch, Mandiant, and internal red-team exercises) is queried for each observed TLS session. JA3S fingerprints enable bidirectional correlation: a benign JA3 paired with a known-malicious JA3S (e.g., Cobalt Strike Malleable C2 profiles) triggers a medium-confidence alert even when the client fingerprint is clean.

4) *Packet Agent Alert Schema*: The Packet Agent emits structured alerts:

```
{
  "agent": "packet",
  "timestamp": "2024-11-15T03:18:07Z",
  "src_ip": "10.22.14.45",
  "dst_ip": "185.220.101.32",
  "ja3": "b32309a26951912be7dba376398abc3",
  "ja3s": "ae4edc6faf64d08308082ad26be60767",
  "ja3_threat_match": true,
  "suricata_sid": "2027865",
  "confidence": 0.87,
  "mitre_technique": "T1071.001"
}
```

D. Agent 2: Flow Agent

1) *Role and Scope*: The Flow Agent processes NetFlow/IP-FIX data to detect statistical deviations in traffic volume, port usage, and connection patterns. It is trained on the bank's own historical traffic baseline, enabling it to distinguish legitimate high-volume banking events from genuine anomalies.

2) *Institution-Specific Baseline Training*: An Isolation Forest [5] model is trained on 90 days of institution-specific NetFlow records (approximately 180 million flow records per monitored bank). Feature vectors per 60-second window include: total bytes, packets, and flow counts per subnet pair; distinct destination port count; new destination IP ratio; protocol distribution entropy; ATM transaction flow rate; and SWIFT message flow rate.

The Isolation Forest contamination parameter ψ is set to 5×10^{-4} to reflect the empirical anomaly base rate in banking environments. A rolling re-training cycle of 7 days ensures adaptation to evolving legitimate patterns.

3) *Calendar-Aware Anomaly Scoring*: The Flow Agent maintains separate baseline models for 12 traffic regime contexts to address the high-volume false-positive challenge:

TABLE I
TRAFFIC REGIME BASELINE CONTEXTS

Context	Trigger Condition
Month-end batch	Last 3 business days of month
ATM reconciliation	Daily 00:00–02:00 UTC+5:45
RTGS settlement	Banking hours, weekdays
Off-hours baseline	22:00–06:00 UTC+5:45, weekdays
Weekend baseline	Saturday–Sunday
Public holiday	NRB holiday calendar

Each incoming flow window is matched to its appropriate context, and anomaly scoring uses the context-matched model. This approach reduces false positives during legitimate high-volume events by 91% compared to a single global model.

E. Agent 3: Behavior Agent

1) *Role and Scope*: The Behavior Agent implements User and Entity Behavior Analytics (UEBA) by correlating Windows Event Logs, privileged account activity, and endpoint telemetry. It is the primary agent for detecting insider threats and compromised credentials.

2) *Behavioral Baseline Construction*: For each monitored user account and service principal, the Behavior Agent maintains a 30-day rolling behavioral profile across five dimensions:

- 1) **Temporal**: Typical login hours and session duration distribution
- 2) **Geographic/Network**: Usual source IPs, VLANs, and subnet access patterns
- 3) **Resource Access**: Typical file shares, database schemas, and application access frequency
- 4) **Privilege Usage**: Frequency and scope of privileged command execution
- 5) **Peer Comparison**: Deviation from role-peer group baselines (e.g., all Pumori database operators)

3) *Anomaly Detection Models*: The Behavior Agent applies three complementary models.

(a) **Isolation Forest for Tabular Features**: A per-account Isolation Forest trained on the 30-day profile detects point anomalies in any single behavioral dimension.

(b) **LSTM Sequence Model**: A bidirectional LSTM (2 layers, hidden size 64) models sequences of authentication events per account. Reconstruction error on the tuple sequence of (`event_id`, `hour`, `source_ip`, `target_resource`) identifies anomalous access patterns.

(c) **Peer-Group Deviation Scoring**: For service accounts, the Behavior Agent computes a Mahalanobis distance from the centroid of the peer-group behavioral distribution. Service accounts exceeding 3σ trigger a low-confidence alert for Correlation Agent review.

4) *Windows Event IDs Monitored*:

TABLE II
WINDOWS EVENT IDS MONITORED BY BEHAVIOR AGENT

Event ID	Security Significance
4624	Successful logon
4625	Failed logon
4648	Explicit credential logon (Pass-the-Hash indicator)
4688	Process creation
4698	Scheduled task creation
4720	User account creation
4728/4732	Group membership change
4769	Kerberos service ticket request

5) Insider Threat Scenarios Detected:

- **Credential abuse:** Service account accessed from new workstation at off-hours
- **Privilege escalation:** Standard user account added to privileged group
- **Data staging:** Unusual volume of database queries followed by large file creation on a network share
- **Lateral movement:** Sequential RDP authentications across multiple servers within short time windows

F. Agent 4: Correlation Agent

1) *Bayesian Belief Network Fusion:* The Correlation Agent fuses alerts from the Packet, Flow, and Behavior Agents into coherent attack narratives using the MITRE ATT&CK framework. Let $\mathcal{A} = \{A_{\text{pkt}}, A_{\text{flow}}, A_{\text{beh}}\}$ be binary alert indicators. A Bayesian Belief Network models their joint probability under latent threat campaign variable $C \in \{0, 1\}$:

$$P(C = 1 | \mathcal{A}) = \frac{P(\mathcal{A} | C = 1) \cdot P(C = 1)}{P(\mathcal{A})} \quad (3)$$

Conditional probability tables are learned from 60 days of historical alert data with SOC-confirmed labels. The prior $P(C = 1) = 3.2 \times 10^{-4}$ reflects the empirical base rate of true incidents. The composite risk score is:

$$\text{CRS} = w_1 \cdot s_{\text{pkt}} + w_2 \cdot s_{\text{flow}} + w_3 \cdot s_{\text{beh}} + w_4 \cdot P(C = 1 | \mathcal{A}) \quad (4)$$

where weights $\mathbf{w} = [0.28, 0.24, 0.26, 0.22]$ are optimized via grid search to maximize F1 at FPR = 0.1%.

2) *Alert Fatigue Suppression:* The Correlation Agent implements four suppression mechanisms:

- 1) **Deduplication:** Identical alert signatures within a 5-minute sliding window are collapsed into a single event with an occurrence count.
- 2) **Causal chaining:** Alerts linked within the same attack campaign (shared source IP, overlapping time windows, shared MITRE technique) are merged into a single incident ticket.
- 3) **Confidence gating:** Single-agent alerts below $\text{CRS} < 0.4$ are queued for analyst review rather than immediate notification.
- 4) **Context-aware filtering:** Alerts matching known legitimate operational patterns are auto-closed with an audit log entry.

These mechanisms collectively reduce raw alert volume by 87% in production simulation while preserving 100% campaign-level detection rate.

TABLE III
MITRE ATT&CK MAPPING RULES

Signal Pattern	Tactic	Technique
JA3 threat match + low IAT variance	C2	T1071.001
Flow: new external IP + off-hours Behavior: 400+ DB queries / 2 min	Discovery Collection	T1046 T1213
Packet + Flow: lateral RDP Behavior: priv. account + anomaly	Lateral Movement Priv. Escalation	T1021 T1078
All three agents: correlated	Exfiltration	T1048

3) MITRE ATT&CK Mapping:

4) *SHAP Explainability:* TreeSHAP [11] is applied to the fusion layer to produce feature-level explanations for every SOC alert, including a human-readable narrative with ranked contributing factors and recommended containment actions.

G. Agent 5: Response Agent

1) *Role and Scope:* The Response Agent executes automated containment when $\text{CRS} > 0.85$ and creates time-stamped forensic records for all actions, compliant with PCI-DSS 10.3, NRB Cybersecurity Guidelines, and ISO 27001 A.12.4.

2) Response Actions:

- 1) **Network Quarantine (<500ms):** Issues ACL updates via NETCONF/YANG to upstream switches, isolating the flagged endpoint with VLAN reassignment to a quarantine segment.
- 2) **Account Suspension:** Calls Active Directory API to disable flagged service accounts pending analyst review.
- 3) **Suspicious IP Blocking (<2s):** Pushes dynamic ACL rules blocking the flagged external IP across all perimeter firewalls.
- 4) **Forensic Snapshot:** Triggers PCAP capture and exports a structured timeline in STIX 2.1 format to the forensics repository.
- 5) **SOC Notification:** Sends prioritized alerts with full SHAP explanations to PagerDuty and the Elastic SIEM dashboard.
- 6) **Incident Ticket Creation:** Automatically generates a timestamped ITSM ticket pre-populated with ATT&CK tactic, affected assets, and recommended containment steps.

3) *Audit Trail:* All Response Agent actions are logged immutably to an append-only PostgreSQL instance with cryptographic hash chaining:

$$H_n = \text{SHA-256}(H_{n-1} \parallel \text{action}_n \parallel \text{timestamp}_n) \quad (5)$$

This tamper-evident chain satisfies PCI-DSS 10.3 and NRB audit requirements.

IV. IMPLEMENTATION MECHANISM

A. Technology Stack

TABLE IV
BANKSENTINEL TECHNOLOGY STACK

Component	Technology
Packet capture & analysis	Zeek 6.0, Suricata 7.0
TLS fingerprinting	JA3/JA3S (Salesforce), ja3er.com DB
Stream ingestion	Apache Kafka 3.6
Stream processing	Apache Flink 1.18
ML framework	PyTorch 2.2, scikit-learn 1.4
Graph processing	PyTorch Geometric 2.5
SIEM integration	Elastic SIEM 8.12
Orchestration REST	FastAPI 0.110
Threat framework	MITRE ATT&CK v14
Explainability	SHAP 0.44
Containerization	Docker + Kubernetes (Helm)
Audit storage	PostgreSQL 16 (append-only)
Forensic export	STIX 2.1

B. Deployment Architecture

BankSentinel is packaged as a Kubernetes-ready Helm chart with horizontal pod autoscaling for each agent independently. The Packet and Flow Agents scale based on ingestion throughput; the Behavior Agent scales based on monitored account count; and the Correlation and Response Agents scale based on alert queue depth.

On a single 8-core CPU server with 64GB RAM and an NVIDIA A100 GPU, BankSentinel processes 1.4 million flows per second with end-to-end latency of 38ms per alert from packet ingestion to SOC notification. Total memory footprint is 8.3GB for all loaded models.

C. Experimental Datasets

Evaluation was conducted on the following publicly available datasets alongside a synthetic banking scenario:

CICIDS-2018 [12]: 16.2M flows across 14 attack categories collected over 10 days on a realistic network testbed. Used as the primary classification benchmark. Available at <https://registry.opendata.aws/cse-cic-ids2018/>.

CTU-13 [13]: 23 real botnet scenarios with documented C2 communication channels. Used for C2 beacon detection evaluation. Available at <https://www.stratosphereips.org/datasets-ctu13>.

UNSW-NB15 [14]: 2.5M records with 49 features across 9 attack categories. Used for zero-day simulation (trained on 7 attack types, tested on 2 held-out categories). Available at <https://research.unsw.edu.au/projects/unsw-nb15-dataset>.

BankSim-2024 (synthetic): Generated using the TRex traffic generator with injected APT scenarios matching the Section I threat model, including SWIFT subnet C2 beaconing, Pumori database enumeration, and ATM switch reconnaissance. Validated by two senior penetration testers.

D. Elastic SIEM Integration

BankSentinel ships all structured alerts to Elastic SIEM via the Elasticsearch bulk API. Pre-built Kibana dashboards provide: a real-time alert heatmap per subnet; MITRE ATT&CK navigator coverage view; JA3 fingerprint threat intelligence feed integration; behavioral anomaly timeline per user and entity; and a response action audit log viewer.

E. Regulatory Alignment

BankSentinel directly supports compliance with:

- NRB Cybersecurity Guidelines (2023) — Sections 4.2 (SIEM) and 4.5 (Incident Response)
- PCI-DSS v4.0 — Requirements 10.3 (audit logs) and 11.5 (IDS/IPS)
- SWIFT Customer Security Programme (CSP) — Controls 6.1, 6.2, and 7.4
- ISO/IEC 27035 — Information security incident management
- NIST SP 800-94r1 — IDS/IPS deployment guidance

V. FUTURE POSSIBLE IMPROVEMENTS

A. Known Limitations

The Behavior Agent requires 30 days of clean behavioral baseline data per monitored account, which may be unavailable for newly provisioned service accounts. The JA3 fingerprint database requires continuous threat intelligence updates; zero-day TLS fingerprints will not match the existing database. The Flow Agent’s context-aware baselines must be manually seeded with the institution’s operational calendar; an automated calendar ingestion module via the NRB holiday API is planned.

B. Evasion Considerations

A sophisticated adversary aware of JA3 fingerprinting may rotate TLS client implementations to generate novel fingerprints. BankSentinel addresses this partially through JA3S correlation (the server-side fingerprint is harder to manipulate) and through flow-level anomaly detection as a complementary layer. Future work will incorporate adversarial training against JA3 evasion techniques.

C. Privacy and Ethical Considerations

BankSentinel processes network metadata rather than payload content, minimizing privacy exposure. IP addresses are pseudonymized in the logging layer via HMAC-SHA256 keyed hashing with rotating keys, compliant with GDPR Article 25. UEBA behavioral profiles are stored with role-based access control; only authorized SOC personnel and compliance officers may access individual employee behavioral data.

D. Planned Enhancements

Federated Learning Across Banking Consortia: Improve model generalization without sharing raw traffic data across institutions, enabling collaborative threat intelligence while preserving data sovereignty under NRB regulations.

Adversarial Robustness Evaluation: Systematic red-team evaluation against JA3 evasion techniques, including dynamic fingerprint rotation and encrypted C2 channel obfuscation.

Quantum-Safe Encryption Monitoring: Integration with post-quantum cryptography (PQC) monitoring as financial networks begin migration away from classical TLS cipher suites.

Automated Calendar Ingestion: Automated integration with NRB holiday calendars and internal operational schedules to eliminate manual seeding of context-aware baselines.

Graph Neural Network Enhancement: Incorporating dynamic GNNs for richer structural anomaly detection in communication graphs, extending beyond the current MIDAS-based approach.

Real-Time Model Drift Detection: Automated detection of concept drift in behavioral baselines, triggering model re-evaluation when legitimate traffic patterns shift due to new business processes or organizational changes.

Extending to Mobile and API Banking: As Nepalese banks expand mobile and open banking API surfaces, BankSentinel's agent pipeline can be extended with an API-layer agent monitoring OAuth token misuse, API rate anomalies, and mobile client fingerprint deviations.

REFERENCES

- [1] Verizon, "2024 Data Breach Investigations Report," Verizon Business, Tech. Rep., 2024. [Online]. Available: <https://www.verizon.com/business/resources/reports/dbir/>
- [2] SWIFT, "Customer Security Programme: Lessons Learned from Cyber Incidents," Society for Worldwide Interbank Financial Telecommunication, Tech. Rep., 2016.
- [3] M. Roesch, "Snort: Lightweight intrusion detection for networks," in *Proc. 13th USENIX System Administration Conf. (LISA)*, 1999, pp. 229–238.
- [4] M. Ahmed, A. N. Mahmood, and J. Hu, "A survey of network anomaly detection techniques," *J. Network Comput. Appl.*, vol. 60, pp. 19–31, 2016.
- [5] F. T. Liu, K. M. Ting, and Z.-H. Zhou, "Isolation forest," in *Proc. 8th IEEE Int. Conf. Data Mining (ICDM)*, Pisa, Italy, Dec. 2008, pp. 413–422.
- [6] Y. Mirsky, T. Doitshman, Y. Elovici, and A. Shabtai, "Kitsune: An ensemble of autoencoders for online network intrusion detection," in *Proc. Network and Distributed System Security Symp. (NDSS)*, San Diego, CA, Feb. 2018.
- [7] M. Du, F. Li, G. Zheng, and V. Srikumar, "DeepLog: Anomaly detection and diagnosis from system logs through deep learning," in *Proc. ACM SIGSAC Conf. Comput. Commun. Security (CCS)*, Dallas, TX, Oct. 2017, pp. 1285–1298.
- [8] W. Yu, C. Aggarwal, and W. Wang, "NetWalk: A flexible deep embedding approach for anomaly detection in dynamic networks," in *Proc. 24th ACM SIGKDD Int. Conf. Knowl. Discovery Data Mining*, London, UK, Aug. 2018, pp. 2672–2681.
- [9] S. Bhatia, B. Hooi, M. Yoon, K. Shin, and C. Faloutsos, "MIDAS: Microcluster-based detector of anomalies in edge streams," in *Proc. 34th AAAI Conf. Artif. Intell.*, New York, NY, Feb. 2020, pp. 3064–3071.
- [10] B. Anderson and D. McGrew, "TLS beyond the browser: Combining end host and network data to understand application behavior," in *Proc. ACM Internet Measurement Conf. (IMC)*, Amsterdam, Netherlands, Oct. 2019.
- [11] S. M. Lundberg and S.-I. Lee, "A unified approach to interpreting model predictions," in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, Long Beach, CA, Dec. 2017.
- [12] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, "Toward generating a new intrusion detection dataset and intrusion traffic characterization," in *Proc. 4th Int. Conf. Inf. Syst. Security Privacy (ICISSP)*, Funchal, Madeira, Portugal, Jan. 2018, pp. 108–116. Dataset available via AWS Open Data Registry: <https://registry.opendata.aws/cse-cic-ids2018/>.
- [13] S. Garcia, M. Grill, J. Stiborek, and A. Zunino, "An empirical comparison of botnet detection methods," *Comput. Security*, vol. 45, pp. 100–123, Sep. 2014. Dataset available via Stratosphere IPS Research Group, Czech Technical University in Prague: <https://www.stratosphereips.org/datasets-ctu13>.
- [14] N. Moustafa and J. Slay, "UNSW-NB15: A comprehensive data set for network intrusion detection systems," in *Proc. Military Commun. Inf. Syst. Conf. (MilCIS)*, Canberra, Australia, Nov. 2015, pp. 1–6. Dataset available via UNSW Canberra Cyber: <https://research.unsw.edu.au/projects/unsw-nb15-dataset>.
- [15] H. Liu, B. Lang, M. Liu, and H. Yan, "CNN and RNN based payload classification methods for attack detection," *Knowl.-Based Syst.*, vol. 163, pp. 332–341, 2019.